13 — Politique de sécurité de l'information (résumé public)

English: ../en/13-security-policy.md

> **MODÈLE.** Résumé destiné aux clients et partenaires. Chaque affirmation doit rester vraie : relire à chaque version (référence technique : `docs/fr/securite.md`).

Cartouche	
Juridiction	RDC — Code du numérique (obligation de sécurité du responsable et du sous-traitant)
Hypothèses	H-03, H-04, H-15
Sources	S01 ; audit `docs/fr/03-audit-securite.md`
Clauses à valider	engagement de notification (V-06)
Version	2.0.0 — [DATE]

Nos engagements

1. **Vos données restent séparées** : la base de données isole chaque établissement (sécurité au niveau des lignes, imposée par la base elle-même) ; nos tests vérifient qu'un établissement ne peut pas lire ceux des autres.
2. **Vos échanges sont chiffrés** : les applications n'acceptent que des connexions HTTPS vers le serveur.
3. **Vos mots de passe ne sont jamais stockés en clair** : ils sont protégés par Argon2id. Minimum 8 caractères, mots de passe trop courants refusés, tentatives limitées. Nous ne vous imposerons pas de changement périodique.
4. **Chaque action est tracée** : le journal d'activité de votre établissement enregistre qui a fait quoi ; aucune fonction de Nhill ne permet de le modifier ou de l'effacer, ni à vous ni à notre équipe (le rôle de la base utilisé par l'application n'en a pas le droit).
5. **Notre équipe n'accède pas à vos documents** : la console d'administration ne donne accès ni à vos factures ni à vos clients ; l'accès direct à la base est réservé à l'exploitation technique (maintenance, sauvegardes) ; nous consultons seulement des chiffres globaux d'utilisation, et chaque consultation apparaît dans votre journal.
6. **Nos administrateurs utilisent une double authentification** obligatoire.
7. **Sauvegardes chiffrées** quotidiennes, avec test de restauration **[à n'affirmer qu'une fois la sauvegarde de production en place et une restauration testée]**.
8. **Aucun secret dans les applications** : elles ne contiennent ni mot de passe de base de données ni clé d'accès.

Ce que nous ne promettons pas

Aucun logiciel n'est exempt de failles. Nhill n'a pas encore fait l'objet d'un audit externe ni d'un test d'intrusion indépendant ; nous le prévoyons avant un déploiement à grande échelle et publierons sa date.

Ce que nous attendons de vous

Un compte par personne ; retirer l’accès des employés qui partent ; un mot de passe propre à Nhill (une courte phrase se retient facilement) ; un poste à jour avec un antivirus actif ; nous signaler toute activité suspecte.

Incidents

En cas de violation de données vous concernant, nous vous prévenons dans les meilleurs délais (au plus tard [24] heures après en avoir eu connaissance) avec ce que nous savons et les mesures prises (procédure : modèle 14).

Signaler une faille

[E-MAIL DE SÉCURITÉ] — merci de ne pas exploiter ni divulguer la faille avant correction.